

Cobalt Ridge Logistics: Supplier Information Security Questionnaire (v2.3)

FICTIONAL SAMPLE written for a portfolio. Cobalt Ridge Logistics is not a real company.

Thank you for completing this questionnaire. Please answer every question on the 'Questionnaire' sheet.

1. Choose Yes, No or N/A in the Response column.
2. Explain your answer in the Explanation column. Answers of 'No' or 'N/A' must be explained.
3. Name the policy or document that supports your answer in the Evidence column. Attach documents if requested.
4. Return the completed file to vendor-security@cobaltridge.example by the due date.

Due date: 16 October 2026

Supplier Information Security Questionnaire

Supplier name:

Completed by (name, title, date):

Ref	Domain	Question	Response (Yes/No/N/A)	Explanation / Details	Evidence / Reference
GOVERNANCE					
GV-01	Governance	Does your organisation maintain written information security policies that have been approved by senior management?	Yes	Yes. Quarterhour has written security policies covering access control, incident response, backup and recovery, business continuity and disaster recovery, encryption, secure development and vendor management. Each policy is owned by the CTO and approved by the CEO.	Source: Access Control Policy v1.3, Document control (the same block heads every policy)
GV-02	Governance	Name the individual or role with overall responsibility for information security.		Dana Whitfield, CTO, owns all of Quarterhour's security policies and leads the response to security incidents as Incident Lead.	Source: Incident Response Plan v1.1, 4. Roles (and the Owner line in every policy)
GV-03	Governance	How frequently are your security policies reviewed, and when were they last updated?	Yes	Each security policy is reviewed at least once a year and after any significant change to systems or the organisation. The current versions were reviewed between March and August 2026.	Source: Access Control Policy v1.3, 9. Policy review (and the review dates in each policy)
GV-04	Governance	Do you perform a documented information security risk assessment at least annually?		NEEDS CLIENT INPUT	
CERTIFICATIONS AND AUDITS					
CA-01	Certifications and audits	Do you currently hold a SOC 2 Type 2 report or ISO 27001 certification? If yes, please attach the most recent report or certificate.	No	No. Quarterhour is not certified to ISO/IEC 27001.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q2
CA-02	Certifications and audits	When was your most recent penetration test by an independent firm, and will you share the executive summary?	Yes	An independent third party performs a penetration test of the Quarterhour application and its public infrastructure at least once a year. Findings are fixed within Quarterhour's remediation times (critical: 7 days; high: 30 days).	Source: Secure Development Policy v1.2, 8. Penetration testing (and 7)
CA-03	Certifications and audits	Do you maintain cyber liability insurance? Please state the coverage limit.		NEEDS CLIENT INPUT	
PEOPLE					
PS-01	People	Are pre-employment background checks completed for staff before they are granted system access?	Yes	Yes. Every employee has a background check before their start date, covering identity, employment history and, where the law allows, criminal records. Contractors with access to production systems are checked the same way.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q3
PS-02	People	Do all employees complete security and privacy awareness training at onboarding and annually thereafter?	Yes	Yes. All staff complete security and privacy awareness training when they join and once a year after that. Engineers also complete secure coding training based on the OWASP Top 10 when they join and every year.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q5 (and Secure Development Policy v1.2, 9. Training)
PS-03	People	When someone leaves your company, how quickly are their accounts disabled?	Yes	When someone leaves, all of their access is revoked within 24 hours of their last working day, or on the same day for involuntary departures. Company devices are returned and wiped.	Source: Access Control Policy v1.3, 6. Joiners, movers and leavers
ACCESS MANAGEMENT					
AM-01	Access management	Is multi-factor authentication enforced for all employee access to email, cloud consoles and source code repositories?	Yes	Yes. Multi-factor authentication is required for all workforce accounts on Google Workspace, AWS, GitHub and Stripe, and on any other system that supports it.	Source: Access Control Policy v1.3, 4.2 Multi-factor authentication
AM-02	Access management	How do you restrict and monitor administrator-level access to production infrastructure?	Yes	Administrator access to the production AWS account is limited to the CTO and two named senior engineers, each using an individual account protected by a hardware security key or authenticator app. The AWS root user has no access keys and is used only when required, and every use of the break-glass account is logged and reviewed by the CTO.	Source: Access Control Policy v1.3, 5.1 Production administrators (and 5.3)

Ref	Domain	Question	Response (Yes/No/N/A)	Explanation / Details	Evidence / Reference
AM-03	Access management	Are user access rights reviewed periodically? State the review frequency.	Yes	Every quarter, the CTO reviews user access to AWS, GitHub, Google Workspace and production database roles. The results and any changes are recorded in the access register.	Source: Access Control Policy v1.3, 7. Access reviews
AM-04	Access management	Do any of your staff share user IDs or use generic accounts to access systems?	No	No. Every person has an individual, named account, and shared or generic accounts are not allowed. The only exception is a sealed break-glass administrator account for emergencies; every use of it is logged and reviewed by the CTO.	Source: Access Control Policy v1.3, 3. Principles (and 5.3 Root and break-glass accounts)
AM-05	Access management	Can our employees sign in to your platform with our corporate identity provider using SAML?		NEEDS CLIENT INPUT	
AM-06	Access management	Is single sign-on used for your staff to access internal business applications?		Partly. Google Workspace is the company identity provider, and internal applications that support single sign-on must use it. The few tools that do not support single sign-on use separate accounts with multi-factor authentication where supported and unique passwords kept in the company password manager.	Source: Access Control Policy v1.3, 4.1 Single sign-on
DATA PROTECTION					
DP-01	Data protection	Is our data encrypted while stored in your databases, file storage and backups? Specify the algorithm.	Yes	Yes. Customer data stored in Amazon RDS, Amazon S3 and EBS volumes is encrypted at rest with AES-256 using AWS Key Management Service (KMS), and all backups and snapshots are encrypted with AES-256 too. Calendar connection (OAuth) tokens are also encrypted at the application level.	Source: Encryption and Key Management Standard v1.1, 2. Data at rest (and Backup and Recovery Policy v1.2, 6. Encryption)
DP-02	Data protection	Which protocol versions protect data travelling between our users and your service?	Yes	All public endpoints accept only HTTPS connections using TLS 1.2 or higher. HTTP requests are redirected to HTTPS and HSTS is enabled. Traffic between internal services and to the database also uses TLS.	Source: Encryption and Key Management Standard v1.1, 3. Data in transit
DP-03	Data protection	Describe how cryptographic keys are generated, stored, rotated and access-controlled.	Yes	Encryption keys are customer managed keys in AWS Key Management Service (KMS), and key material never leaves KMS. IAM policies restrict each key to the services and administrators that need it, every use of a key is logged in AWS CloudTrail, and automatic annual key rotation is enabled.	Source: Encryption and Key Management Standard v1.1, 4. Key management
DP-04	Data protection	Where geographically will our data reside? List all hosting locations, including backups.		Customer data is hosted on AWS in the us-east-1 region (United States). Backups are copied to the AWS us-west-2 region (United States).	Source: Backup and Recovery Policy v1.2, 2. Scope and 5. Backup location
DP-05	Data protection	How is our data logically separated from data belonging to your other customers?	Yes	Quarterhour is a multi-tenant service with logical separation: every record carries the customer's account ID, and the application's data-access layer limits every query to the signed-in customer's account.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q6
DP-06	Data protection	Will any of our data be used to train artificial intelligence or machine learning models?	No	No. Quarterhour does not use customer data to train AI or machine learning models, and does not send customer data to third-party AI services.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q9
DP-07	Data protection	When our contract ends, how and when is our data returned or deleted, including from backups?	Yes	Customer data is kept while the contract is active. When a contract ends, the customer can export their data for 30 days, and it is then deleted from production systems. Deleted data remains in encrypted backups until those backups expire: 35 days for daily backups and up to 12 months for monthly snapshots.	Source: Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q7 (and Backup and Recovery Policy v1.2, 4. Retention)
DP-08	Data protection	Is live customer data ever used in your development or testing environments?	No	No. Production customer data is never copied to development or staging; those environments use synthetic test data. The quarterly backup restore test uses an isolated environment, and the restored copy is deleted after the test.	Source: Secure Development Policy v1.2, 5. Environments (and Backup and Recovery Policy v1.2, 8. Restore testing)
OPERATIONS AND MONITORING					
OM-01	Operations and monitoring	Do you collect audit logs of security events, and for how long are they retained?		NEEDS CLIENT INPUT	
OM-02	Operations and monitoring	Is suspicious activity in your environment detected and alerted on around the clock?	Yes	Yes. Security alerts from AWS GuardDuty, AWS CloudTrail, application error monitoring and uptime checks go to the on-call engineer, and suspected incidents are handled under the Incident Response Plan.	Source: Incident Response Plan v1.1, 5. Detection and reporting

Ref	Domain	Question	Response (Yes/No/N/A)	Explanation / Details	Evidence / Reference
OM-03	Operations and monitoring	Do you have a web application firewall or DDoS protection in front of your application?		NEEDS CLIENT INPUT	
OM-04	Operations and monitoring	Are staff laptops protected with full-disk encryption and managed centrally?	Yes	Yes. Company laptops must have full-disk encryption (FileVault) turned on, and this is checked through the company's device management (MDM) tool.	Source: Encryption and Key Management Standard v1.1, 6. Laptops
OM-05	Operations and monitoring	Do company computers run anti-malware or endpoint detection and response software?		NEEDS CLIENT INPUT	
SECURE DEVELOPMENT					
SD-01	Secure development	Is every code change reviewed by a second person before release to production?	Yes	Yes. Every change is made through a pull request and needs at least one approving review from an engineer other than the author before it can be merged. The main branch is protected, and only code merged to it can be deployed to production.	Source: Secure Development Policy v1.2, 3. Code review (and 2, 6)
SD-02	Secure development	Do you run automated security scanning (static analysis, dependency checks) in your build pipeline?	Yes	Yes. Every pull request runs automated tests, static code analysis for common security flaws and dependency scanning for known vulnerable packages. Secret scanning is turned on for all repositories, and a pull request cannot be merged while a required check is failing.	Source: Secure Development Policy v1.2, 4. Automated checks
SD-03	Secure development	What are your target timeframes for fixing critical and high severity vulnerabilities?	Yes	Confirmed vulnerabilities are fixed within these times: critical within 7 days, high within 30 days, medium within 90 days, and low at the next planned update.	Source: Secure Development Policy v1.2, 7. Vulnerability remediation
SD-04	Secure development	Are production and non-production environments logically or physically separated?	Yes	Yes. Development, staging and production are separate, and staging and production run in separate AWS accounts. Production customer data is never copied to development or staging.	Source: Secure Development Policy v1.2, 5. Environments
RESILIENCE					
RS-01	Resilience	How often are backups of our data taken, and where are they stored?	Yes	The production database is backed up automatically every day, and transaction logs allow point-in-time recovery to any moment in the retention period, normally to within 5 minutes. Versioning is turned on for the storage buckets that hold customer files.	Source: Backup and Recovery Policy v1.2, 3. Backup frequency
RS-02	Resilience	Are backup restorations tested? How often?	Yes	Yes. Every quarter, engineering restores the production database from backup into an isolated test environment, checks that the data is complete, and records the result and the time taken.	Source: Backup and Recovery Policy v1.2, 8. Restore testing
RS-03	Resilience	What recovery time and recovery point objectives do you commit to for the service?	Yes	The recovery time objective (RTO) is 8 hours and the recovery point objective (RPO) is 1 hour.	Source: Business Continuity and Disaster Recovery Plan v1.0, 3. Recovery objectives
RS-04	Resilience	Describe how you would restore the service if your primary hosting region became unavailable.	Yes	If the primary AWS region (us-east-1) becomes unavailable, the team rebuilds the service in the us-west-2 region from cross-region backups, using infrastructure-as-code templates. The CTO decides when to start regional recovery.	Source: Business Continuity and Disaster Recovery Plan v1.0, 5. Disaster recovery
INCIDENTS AND THIRD PARTIES					
IN-01	Incidents and third parties	Within what timeframe will you notify us after confirming a security breach affecting our data?	Yes	If a security incident affects customer data, Quarterhour notifies the affected customers without undue delay and no later than 72 hours after confirming the incident. The notice explains what happened, which data was involved, what is being done and who to contact.	Source: Incident Response Plan v1.1, 7. Customer notification
IN-02	Incidents and third parties	Is your incident response plan exercised at least annually?	Yes	Yes. The incident response plan is tested with a tabletop exercise at least once a year, and the results and any improvements are recorded.	Source: Incident Response Plan v1.1, 9. Testing
TP-01	Incidents and third parties	Do you assess the security posture of your own suppliers and subprocessors before sharing data with them?	Yes	Yes. Before a new vendor receives customer data, the contract owner completes a vendor risk review. For high-risk vendors (those that store or process customer data), Quarterhour reviews the vendor's SOC 2 report, ISO 27001 certificate or completed security questionnaire, and the CTO approves the vendor. A data processing agreement is signed if the vendor will process personal data.	Source: Vendor Management Policy v1.0, 3. Assessment before use

Review: cobalt-ridge-supplier-security-questionnaire.xlsx (remove this sheet before sending to the buyer)

40 questions: 17 OK, 17 CHECK, 6 NEEDS CLIENT INPUT. Library: answer_library.xlsx (70 approved answers). Generated 2026-10-07.

How to finish: fix every NEEDS CLIENT INPUT and CHECK row in the questionnaire (click the Cell link to jump there), then type Y in Resolved. Wrong match? Type the right library ID (or NONE) in 'Use library ID' and rerun with --use-review. The client's technical owner must read and approve every answer. Delete this sheet, or run fill_questionnaire.py --finalize, before sending.

Score: how close the buyer's question is to the library question, from 0 to 1 (70% TF-IDF keyword match + 30% fuzzy text match). OK at 0.50 or more; CHECK at 0.25 or more; lower means no match. Shared keywords show why it matched; Runner-up is the next best library entry.

Status	Ref	Cell	Buyer question	Proposed Yes/No	Proposed answer	Source	What to do	Library ID	Score	Reviewer notes
NEEDS CLIENT INPUT	GV-04	F10	Do you perform a documented information security risk assessment at least annually?				Matches GOV-004 (score 0.61), which has no approved answer yet. Ask the client, then update GOV-004 in the library.	GOV-004	0.61	
NEEDS CLIENT INPUT	CA-03	F14	Do you maintain cyber liability insurance? Please state the coverage limit.				Matches CMP-005 (score 0.77), which has no approved answer yet. Ask the client, then update CMP-005 in the library.	CMP-005	0.77	
NEEDS CLIENT INPUT	AM-05	F24	Can our employees sign in to your platform with our corporate identity provider using SAML?				Matches AC-005 (score 0.51), which has no approved answer yet. Ask the client, then update AC-005 in the library.	AC-005	0.51	
NEEDS CLIENT INPUT	OM-01	F36	Do you collect audit logs of security events, and for how long are they retained?				Matches LOG-002 (score 0.50), which has no approved answer yet. Ask the client, then update LOG-002 in the library.	LOG-002	0.50	Logging is covered by LOG-001 but log retention is not in any document. Ask the CTO.
NEEDS CLIENT INPUT	OM-03	F38	Do you have a web application firewall or DDoS protection in front of your application?				Matches NET-004 (score 0.83), which has no approved answer yet. Ask the client, then update NET-004 in the library.	NET-004	0.83	
NEEDS CLIENT INPUT	OM-05	F40	Do company computers run anti-malware or endpoint detection and response software?				Matches END-002 (score 0.65), which has no approved answer yet. Ask the client, then update END-002 in the library.	END-002	0.65	
CHECK	GV-02	F8	Name the individual or role with overall responsibility for information security.		Dana Whitfield, CTO, owns all of Quarterhour's security policies and leads the response to security incidents as Incident Lead.	Incident Response Plan v1.1, 4. Roles (and the Owner line in every policy)	Score 0.33 is below 0.50: confirm GOV-002 really answers this question.	GOV-002	0.33	
CHECK	GV-03	F9	How frequently are your security policies reviewed, and when were they last updated?	Yes	Each security policy is reviewed at least once a year and after any significant change to systems or the organisation. The current versions were reviewed between March and August 2026.	Access Control Policy v1.3, 9. Policy review (and the review dates in each policy)	The question asks for specifics (a date, number, list or attachment): make sure the answer covers them.	GOV-003	0.56	
CHECK	CA-01	F12	Do you currently hold a SOC 2 Type 2 report or ISO 27001 certification? If yes, please attach the most recent report or certificate.	No	No. Quarterhour is not certified to ISO/IEC 27001.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q2	Score 0.48 is below 0.50: confirm CMP-002 really answers this question. The question asks for specifics (a date, number, list or attachment): make sure the answer covers them.	CMP-002	0.48	Two questions in one: the answer covers ISO 27001 only. Add the SOC 2 sentence from CMP-001 by hand.
CHECK	CA-02	F13	When was your most recent penetration test by an independent firm, and will you share the executive summary?	Yes	Yes. An independent third party performs a penetration test of the Quarterhour application and its public infrastructure at least once a year. Findings are fixed within Quarterhour's remediation times (critical: 7 days; high: 30 days).	Secure Development Policy v1.2, 8. Penetration testing (and 7)	The question asks for specifics (a date, number, list or attachment): make sure the answer covers them.	VUL-001	0.54	
CHECK	PS-01	F16	Are pre-employment background checks completed for staff before they are granted system access?	Yes	Yes. Every employee has a background check before their start date, covering identity, employment history and, where the law allows, criminal records. Contractors with access to production systems are checked the same way.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q3	Score 0.43 is below 0.50: confirm HR-001 really answers this question.	HR-001	0.43	
CHECK	PS-03	F18	When someone leaves your company, how quickly are their accounts disabled?	Yes	When someone leaves, all of their access is revoked within 24 hours of their last working day, or on the same day for involuntary departures. Company devices are returned and wiped.	Access Control Policy v1.3, 6. Joiners, movers and leavers	Score 0.42 is below 0.50: confirm HR-004 really answers this question.	HR-004	0.42	
CHECK	AM-04	F23	Do any of your staff share user IDs or use generic accounts to access systems?	No	No. Every person has an individual, named account, and shared or generic accounts are not allowed. The only exception is a sealed break-glass administrator account for emergencies; every use of it is logged and reviewed by the CTO.	Access Control Policy v1.3, 3. Principles (and 5.3 Root and break-glass accounts)	Score 0.40 is below 0.50: confirm AC-009 really answers this question.	AC-009	0.40	
CHECK	AM-06	F25	Is single sign-on used for your staff to access internal business applications?	Partial	Partly. Google Workspace is the company identity provider, and internal applications that support single sign-on must use it. The few tools that do not support single sign-on use separate accounts with multi-factor authentication where supported and unique passwords kept in the company password manager.	Access Control Policy v1.3, 4.1 Single sign-on	Short answer 'Partial' is not in this column's drop-down (Yes, No, N/A): choose one with the client.	AC-004	0.79	
CHECK	DP-03	F29	Describe how cryptographic keys are generated, stored, rotated and access-controlled.	Yes	Encryption keys are customer managed keys in AWS Key Management Service (KMS), and key material never leaves KMS. IAM policies restrict each key to the services and administrators that need it, every use of a key is logged in AWS CloudTrail, and automatic annual key rotation is enabled.	Encryption and Key Management Standard v1.1, 4. Key management	Score 0.44 is below 0.50: confirm CRY-003 really answers this question.	CRY-003	0.44	

Status	Ref	Cell	Buyer question	Proposed Yes/No	Proposed answer	Source	What to do	Library ID	Score	Reviewer notes
CHECK	DP-04	E30	Where geographically will our data reside? List all hosting locations, including backups.		Customer data is hosted on AWS in the us-east-1 region (United States). Backups are copied to the AWS us-west-2 region (United States).	Backup and Recovery Policy v1.2, 2. Scope and 5. Backup location	Score 0.39 is below 0.50: confirm DAT-002 really answers this question.	DAT-002	0.39	
CHECK	DP-05	E31	How is our data logically separated from data belonging to your other customers?	Yes	Quarterhour is a multi-tenant service with logical separation: every record carries the customer's account ID, and the application's data-access layer limits every query to the signed-in customer's account.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q6	Score 0.43 is below 0.50: confirm DAT-003 really answers this question.	DAT-003	0.43	
CHECK	OM-02	E37	Is suspicious activity in your environment detected and alerted on around the clock?	Yes	Yes. Security alerts from AWS GuardDuty, AWS CloudTrail, application error monitoring and uptime checks go to the on-call engineer, and suspected incidents are handled under the Incident Response Plan.	Incident Response Plan v1.1, 5. Detection and reporting	Score 0.41 is below 0.50: confirm LOG-003 really answers this question.	LOG-003	0.41	Policy says alerts go to the on-call engineer, not that monitoring is 24/7. Ask the CTO.
CHECK	SD-03	E44	What are your target timeframes for fixing critical and high severity vulnerabilities?	Yes	Confirmed vulnerabilities are fixed within these times: critical within 7 days, high within 30 days, medium within 90 days, and low at the next planned update.	Secure Development Policy v1.2, 7. Vulnerability remediation	Score 0.47 is below 0.50: confirm VUL-003 really answers this question.	VUL-003	0.47	
CHECK	RS-01	E47	How often are backups of our data taken, and where are they stored?	Yes	The production database is backed up automatically every day, and transaction logs allow point-in-time recovery to any moment in the retention period, normally to within 5 minutes. Versioning is turned on for the storage buckets that hold customer files.	Backup and Recovery Policy v1.2, 3. Backup frequency	Score 0.40 is below 0.50: confirm BCK-001 really answers this question. Close second match BCK-003 (0.37): make sure the right answer was picked.	BCK-001	0.40	
CHECK	IN-01	E52	Within what timeframe will you notify us after confirming a security breach affecting our data?	Yes	If a security incident affects customer data, Quarterhour notifies the affected customers without undue delay and no later than 72 hours after confirming the incident. The notice explains what happened, which data was involved, what is being done and who to contact.	Incident Response Plan v1.1, 7. Customer notification	Close second match IR-007 (0.51): make sure the right answer was picked.	IR-002	0.51	
CHECK	IN-02	E53	Is your incident response plan exercised at least annually?	Yes	Yes. The incident response plan is tested with a tabletop exercise at least once a year, and the results and any improvements are recorded.	Incident Response Plan v1.1, 9. Testing	Close second match IR-001 (0.62): make sure the right answer was picked.	IR-004	0.64	
CHECK	TP-01	E54	Do you assess the security posture of your own suppliers and subprocessors before sharing data with them?	Yes	Yes. Before a new vendor receives customer data, the contract owner completes a vendor risk review. For high-risk vendors (those that store or process customer data), Quarterhour reviews the vendor's SOC 2 report, ISO 27001 certificate or completed security questionnaire, and the CTO approves the vendor. A data processing agreement is signed if the vendor will process personal data.	Vendor Management Policy v1.0, 3. Assessment before use	Score 0.46 is below 0.50: confirm VEN-001 really answers this question. Close second match VEN-002 (0.43): make sure the right answer was picked.	VEN-001	0.46	
OK	GV-01	E7	Does your organisation maintain written information security policies that have been approved by senior management?	Yes	Yes. Quarterhour has written security policies covering access control, incident response, backup and recovery, business continuity and disaster recovery, encryption, secure development and vendor management. Each policy is owned by the CTO and approved by the CEO.	Access Control Policy v1.3, Document control (the same block heads every policy)	Strong match. Still read the answer before sending.	GOV-001	0.72	
OK	PS-02	E17	Do all employees complete security and privacy awareness training at onboarding and annually thereafter?	Yes	Yes. All staff complete security and privacy awareness training when they join and once a year after that. Engineers also complete secure coding training based on the OWASP Top 10 when they join and every year.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q5 (and Secure Development Policy v1.2, 9. Training)	Strong match. Still read the answer before sending.	HR-003	0.58	
OK	AM-01	E20	Is multi-factor authentication enforced for all employee access to email, cloud consoles and source code repositories?	Yes	Yes. Multi-factor authentication is required for all workforce accounts on Google Workspace, AWS, GitHub and Stripe, and on any other system that supports it.	Access Control Policy v1.3, 4.2 Multi-factor authentication	Strong match. Still read the answer before sending.	AC-002	0.51	
OK	AM-02	E21	How do you restrict and monitor administrator-level access to production infrastructure?	Yes	Administrator access to the production AWS account is limited to the CTO and two named senior engineers, each using an individual account protected by a hardware security key or authenticator app. The AWS root user has no access keys and is used only when required, and every use of the break-glass account is logged and reviewed by the CTO.	Access Control Policy v1.3, 5.1 Production administrators (and 5.3)	Strong match. Still read the answer before sending.	AC-008	0.50	
OK	AM-03	E22	Are user access rights reviewed periodically? State the review frequency.	Yes	Every quarter, the CTO reviews user access to AWS, GitHub, Google Workspace and production database roles. The results and any changes are recorded in the access register.	Access Control Policy v1.3, 7. Access reviews	Strong match. Still read the answer before sending.	AC-007	0.62	
OK	DP-01	E27	Is our data encrypted while stored in your databases, file storage and backups? Specify the algorithm.	Yes	Yes. Customer data stored in Amazon RDS, Amazon S3 and EBS volumes is encrypted at rest with AES-256 using AWS Key Management Service (KMS), and all backups and snapshots are encrypted with AES-256 too. Calendar connection (OAuth) tokens are also encrypted at the application level.	Encryption and Key Management Standard v1.1, 2. Data at rest (and Backup and Recovery Policy v1.2, 6. Encryption)	Strong match. Still read the answer before sending.	CRY-001	0.79	
OK	DP-02	E28	Which protocol versions protect data travelling between our users and your service?	Yes	Yes. All public endpoints accept only HTTPS connections using TLS 1.2 or higher. HTTP requests are redirected to HTTPS and HSTS is enabled. Traffic between internal services and to the database also uses TLS.	Encryption and Key Management Standard v1.1, 3. Data in transit	Library entry CRY-002 was chosen by the reviewer.	CRY-002	0.26	Wrong match. Correct entry: CRY-002 (TLS).
OK	DP-06	E32	Will any of our data be used to train artificial intelligence or machine learning models?	No	No. Quarterhour does not use customer data to train AI or machine learning models, and does not send customer data to third-party AI services.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q9	Strong match. Still read the answer before sending.	DAT-006	0.92	

Status	Ref	Cell	Buyer question	Proposed Yes/No	Proposed answer	Source	What to do	Library ID	Score	Reviewer notes
OK	DP-07	E33	When our contract ends, how and when is our data returned or deleted, including from backups?	Yes	Customer data is kept while the contract is active. When a contract ends, the customer can export their data for 30 days, and it is then deleted from production systems. Deleted data remains in encrypted backups until those backups expire: 35 days for daily backups and up to 12 months for monthly snapshots.	Written answers from Dana Whitfield, CTO, 30 Sep 2026, Q7 (and Backup and Recovery Policy v1.2, 4. Retention)	Strong match. Still read the answer before sending.	DAT-004	0.61	
OK	DP-08	E34	Is live customer data ever used in your development or testing environments?	No	No. Production customer data is never copied to development or staging; those environments use synthetic test data. The quarterly backup restore test uses an isolated environment, and the restored copy is deleted after the test.	Secure Development Policy v1.2, 5. Environments (and Backup and Recovery Policy v1.2, 8. Restore testing)	Strong match. Still read the answer before sending.	DAT-007	0.94	
OK	OM-04	E39	Are staff laptops protected with full-disk encryption and managed centrally?	Yes	Yes. Company laptops must have full-disk encryption (FileVault) turned on, and this is checked through the company's device management (MDM) tool.	Encryption and Key Management Standard v1.1, 6. Laptops	Strong match. Still read the answer before sending.	END-001	0.70	
OK	SD-01	E42	Is every code change reviewed by a second person before release to production?	Yes	Yes. Every change is made through a pull request and needs at least one approving review from an engineer other than the author before it can be merged. The main branch is protected, and only code merged to it can be deployed to production.	Secure Development Policy v1.2, 3. Code review (and 2, 6)	Strong match. Still read the answer before sending.	SDL-002	0.51	
OK	SD-02	E43	Do you run automated security scanning (static analysis, dependency checks) in your build pipeline?	Yes	Yes. Every pull request runs automated tests, static code analysis for common security flaws and dependency scanning for known vulnerable packages. Secret scanning is turned on for all repositories, and a pull request cannot be merged while a required check is failing.	Secure Development Policy v1.2, 4. Automated checks	Strong match. Still read the answer before sending.	SDL-004	0.70	
OK	SD-04	E45	Are production and non-production environments logically or physically separated?	Yes	Yes. Development, staging and production are separate, and staging and production run in separate AWS accounts. Production customer data is never copied to development or staging.	Secure Development Policy v1.2, 5. Environments	Strong match. Still read the answer before sending.	SDL-003	0.72	
OK	RS-02	E48	Are backup restorations tested? How often?	Yes	Yes. Every quarter, engineering restores the production database from backup into an isolated test environment, checks that the data is complete, and records the result and the time taken.	Backup and Recovery Policy v1.2, 8. Restore testing	Strong match. Still read the answer before sending.	BCK-005	0.73	
OK	RS-03	E49	What recovery time and recovery point objectives do you commit to for the service?	Yes	The recovery time objective (RTO) is 8 hours and the recovery point objective (RPO) is 1 hour.	Business Continuity and Disaster Recovery Plan v1.0, 3. Recovery objectives	Strong match. Still read the answer before sending.	BCP-003	0.65	
OK	RS-04	E50	Describe how you would restore the service if your primary hosting region became unavailable.	Yes	Yes. If the primary AWS region (us-east-1) becomes unavailable, the team rebuilds the service in the us-west-2 region from cross-region backups, using infrastructure-as-code templates. The CTO decides when to start regional recovery.	Business Continuity and Disaster Recovery Plan v1.0, 5. Disaster recovery	Library entry BCP-002 was chosen by the reviewer.	BCP-002	0.28	Wrong match (hosting regions). Correct entry: BCP-002.